

CYBER SECURITY Steering Committee

(CSSC 14-07-2025)

XYZ | XYZ Only

Agenda

SN	AGENDA	PRESENTER(S)
1	Red Team Assessment Brief	Vendor-E
2	Introduction & clarification on the pre-read (5 minutes)	Chair
3	Update on previous action items (5 minutes)	P-A
4	Cybersecurity Performance Metrics (5 minutes)	P-A
5	Summary of incidents (10 minutes)	P-A
6	Cybersecurity Emerging Threat Overview (15 minutes)	P-A
7	Journey through maturity (10 minutes)	P-C/P-B/P-A
8	Data Protection and Cyber Risk Grid (10 minutes)	P-B/P-A
8	Open Discussion and Q&A (10 minutes)	

Private & Confidential ©

01.

Red Team Assessment Briefing by Vendor-E

02.

Update on previous action items

Previous Action Items

Entered on	Action discussed	Responsible	Due	Action taken	Status
	Socialize the AI policy and share with Group Legal	P-A	19 June 2025	First draft reviewed, revisions required	In-Progress
	Sub-B Sensitive data analysis	P-B	18 July 2025	Asset Inventory Collected	Completed
	Update the systems of critical vulnerabilities in the list of critical system	P-A		Updated, presented to BAC and included in AB update.	Completed
	Deep dive Bank integration and Kofax vulnerabilities with vendor lead	P-A/P-C	19 June 2025	Scheduled	In Progress
	SA update to be shared	P-C		SA meeting scheduled on 29 May and Direction Received.	Completed



03.

Cybersecurity Performance Metrics

Cybersecurity KPIs Q2 2025

SOC Detections Q2 2025	Priority	Q1 (2025)	Q2 (2025)	SLA	
Mean Time to Respond (by MSSP)	P1	0.3 Hrs	0.9 Hrs	15 mins	↑
	P2			30 mins	
	P3			60 mins	
	P4			120 mins	
Mean Time to Respond (by XYZ SOC)	P1	13.3 Hrs	10.2 Hrs	15 mins	↓
	P2			30 mins	
	P3			45 mins	
	P4			60 mins	
Mean Time to Resolve (MTTR)	P1	26.7 Hrs	38.2 Hrs	24 Hrs	↑
	P2			48 Hrs	
	P3			5 Days	
	P4			14 Days	

* From 2025, Sources of Incidents: SIEM, EDR & TI

* The industry standard for **Mean Time to Respond** in cybersecurity benchmark is around 24 hour

* Average Organizations typically have a Mean **Time to Resolve** ranging from 24 to 72 hours.

Patching Compliance:

Windows Device Compliance	N	N-1	End of Support
End Device	↑ 45.02%	53.63%	2.62%
Servers		99.00%	11.0%

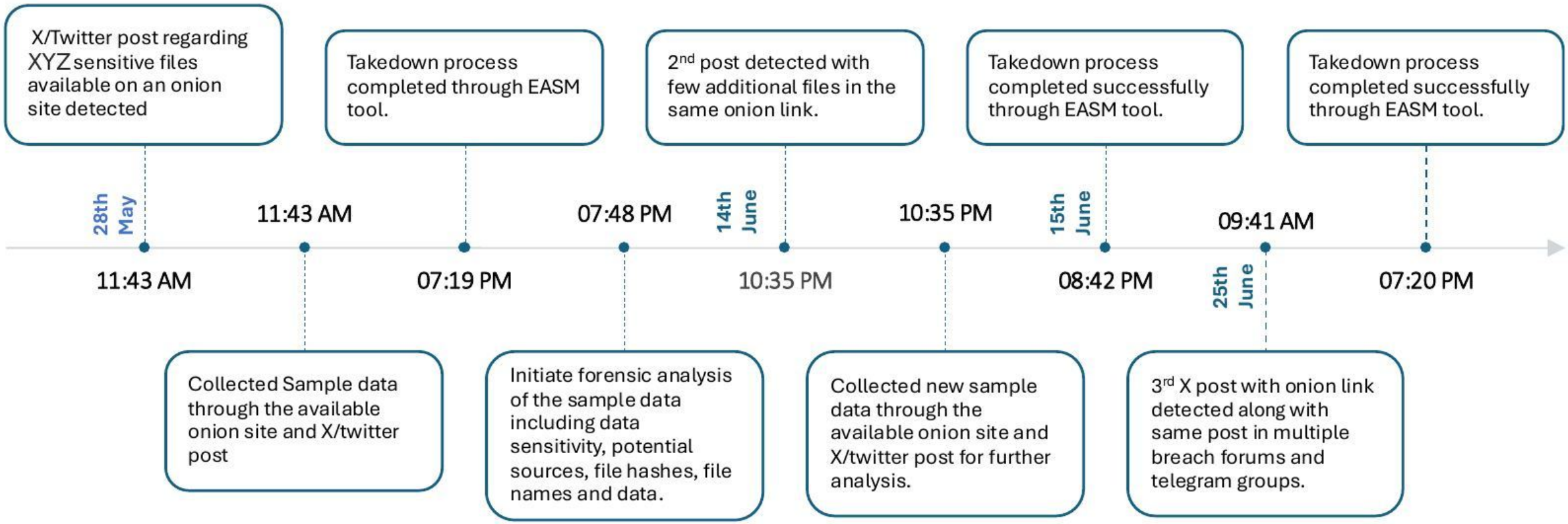
XYZ | XYZ Only *End of support is considered as compliant

04.

Summary of Incidents

Data Leakage Incident

Cyber Risk Grid ID/s



Key Take aways:

- Possible reputation damage could arise from the public rediscovery of previously breach files.

Impact:

- 26 Files were found in the sample breach file

05.

Cybersecurity Emerging Threat Overview

Cybersecurity Emerging Threat Overview



Increase in GenAI Backed Cyber Attacks:

Threat actors increasingly employ GenAI to support social engineering, generate malware scripts, phishing content, decoy websites, with confirmed use in real-world campaigns. Led to increased BEC and organization breaches in 2024. The fastest breakout time recorded as 51s (for lateral movement) from 48mins of average with GenAI.



Escalating Threats Targeting SaaS:

In 2025, threat actors are expected to intensify their exploitation of cloud-based SaaS platforms, with Microsoft 365 particularly SharePoint and Outlook remaining key targets. SharePoint and Outlook were accessed in 22% and 17% of intrusions respectively in early 2024. Adversaries like SCATTERED SPIDER search compromised SharePoint and mailboxes for sensitive data such as credentials and VPN instructions to aid lateral movement.



Emerging Patterns in Vulnerability Exploitation:

In 2024, threat actors increasingly used exploit chaining and abusing legitimate built-in features to bypass controls and escalate privileges. Notable cases include PAN-OS (CVE-2024-0012 & 9474) and Cisco IOS (CVE-2023-20198 & 20273) exploits and SAP NW portal within XYZ. With continuous attacks targeting our external attack surface, Threat actors successfully bypassed WAF defenses in several instances. Indicating evolving tactics in vulnerability exploitation.



Increase in Threat Actor Activities around [country]:

In 2024–2025, [coun has seen a sharp rise in cyber threats, with BFSI institutions, government and education institutes, and gifting platforms increasingly targeted. Notable incidents includes attacks on Sussex college, UoSJ, [coun railways and Dept. of Pensions. Also, sensitive files belongs to XYZ has been identified on darkweb/hacker forums. Additionally, a breach collection containing 1.6 billion leaked credentials from various platforms is actively circulating, increasing credential stuffing and targeted intrusions.

06.

Journey Through Maturity

Software Taxonomy

Software Category Distribution

CATEGORY	Application Count	%
Unknown / Unclassified	2216	40.70%
Utilities	1338	24.57%
Unclassified - Known Publisher	927	17.02%
Business Applications	568	10.43%
Utilities - Apple Services	228	4.19%
Development, Security, Productivity, OS	168	3.09%
Grand Total	**5426**	**100%**

Application Usage Bands (By Device Count)

Used Range (Devices)	Application Count	%
Less than 10	3588	66.13%
Between 10 - 500	1545	28.47%
Between 501- 1000	138	2.54%
Between 1001 - 5000	87	1.60%
Between 5001 - 10000	25	0.46%
Between 10001 - 15000	22	0.41%
Over 15000	21	0.39%
Grand Total	**5426**	**100.00%**

Risk vs. Usage Unit-3 Distribution

Risk	Count	%
Low Usage - Critical Vulnerabilities	8	0.15%
Low Usage - High Vulnerabilities	10	0.18%
Low Usage - Medium/Low Vulnerabilities	4	0.07%
Moderate Usage - Critical Vulnerabilities	29	0.53%
Moderate Usage - High Vulnerabilities	28	0.52%
Moderate Usage - Medium/Low Vulnerabilities	5	0.09%
Wide Usage - Critical Vulnerabilities	10	0.18%
Wide Usage - High Vulnerabilities	7	0.13%
No Vulnerability Information Available	5325	98.14%
Grand Total	**5426**	**100.00%**

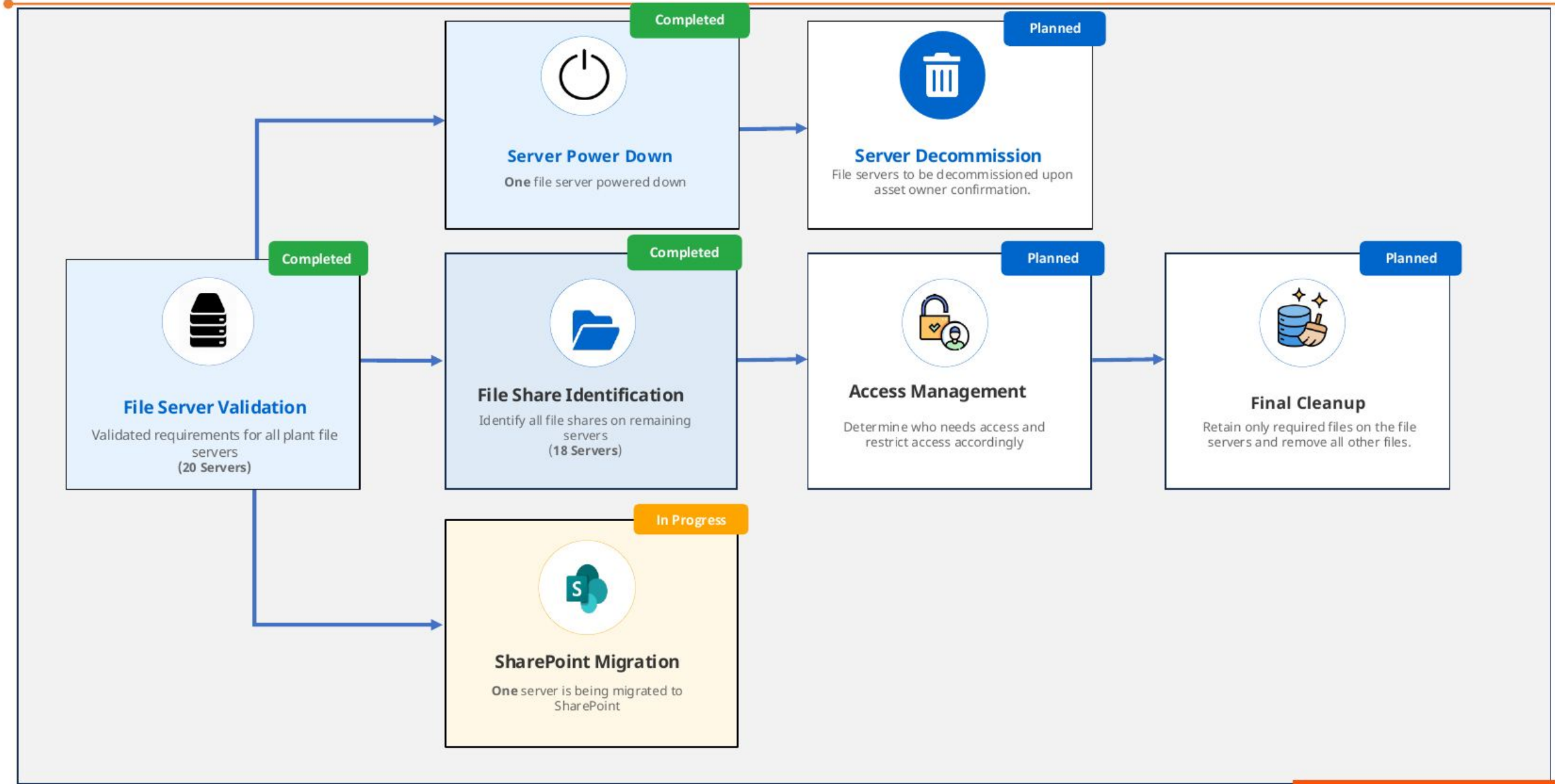
Key Insights

- **Category Distribution**:40% of software is unknown/unclassified.
- **Usage Patterns**: 66% of applications used on fewer than 10 devices.
- **Risk** Unit-398% of apps lack vulnerability data; few (1.7%) show critical/high risk.
- **Unclassified Software**: Includes unauthorized or potentially harmful apps needing investigation and removal.

Next Steps

- Identify core utility applications
- Draft a list of whitelisted applications
- Identify blocking mechanisms for all non-whitelisted applications.
- Communicate the policy to end users.
- Enforce application blocking

SBU File Share Roadmap



Device compliance

CrowdStrike (CS) Coverage
99.88%

CS Coverage	Count
Covered	15529
Not Covered	18

- Intune deployment issue - 12
- Not Installed - 6

ZScaler (ZS) Coverage
99.22%

ZS Coverage	Count
Covered	15426
Not Covered	121

- Subic is still not under XYZ domain, so Zscaler cannot be used in those devices. - 109
- Not Installed – 8
- Intune deployment Issue - 4

Outdated OS

OS	Count
Microsoft Windows 8.1	16
Microsoft Windows 7	2
Linux	29

Qualys Coverage
100%

Qualys Coverage	Count
Covered	771

07.

Data Protection and Cyber Risk Grid

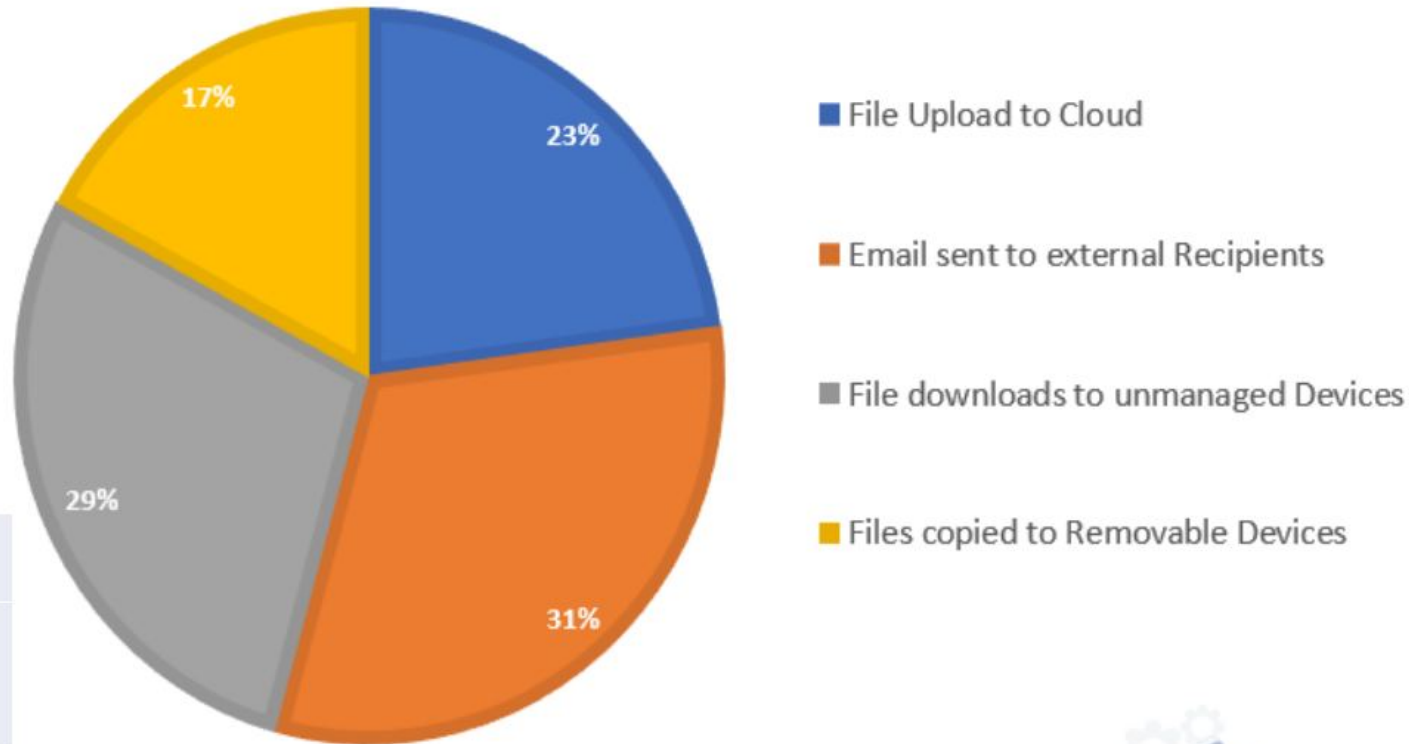
DLP Statistics

Critical Alerts Investigated ir Q2 2025

Status	#
Closed	25
Open*	10
Total	35

*Open incidents are pending user or line manager response

Requirement	Manage and restrict SD/MicroSD Card access
limitations	CrowdStrike Device Control can't block built-in SD/MicroSD card readers
DLP Cases	Two active data loss prevention cases
Current Progress	Identified laptop users with active SD card access & managing them through NAC

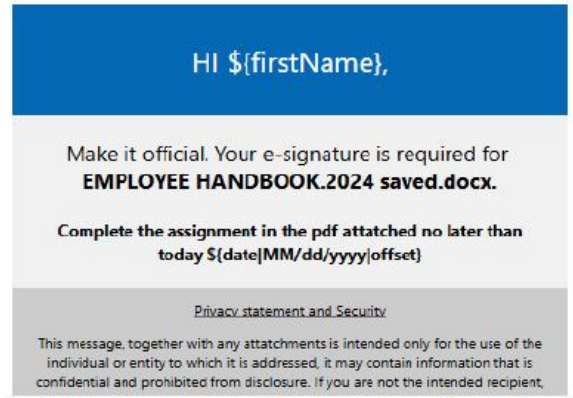




Phishing Simulation 2025

Scope

- All Users



Phishing Simulations	2024(Q1) Legato, Finance, DGM&Above		2024 (Q4) All Users		2025 All Users	
Successfully received the phishing mail	1,133		16,437		**16,238**	
Clicked phishing link	-	-	**3,011**	**18%**	-	-
Supplied credentials/ Attachment opened	90	8%	**1,955**	**12%**	**4,646**	**28%**
Reported as suspicious	71	6%	187	1%	**340**	**2%**

Vulnerabilities in Core Systems

Application	Critical - Q1	Critical - Q2	High - Q1	High - Q2	Percentage
SAP Unit-3	32	26	50	36	-24% ↓
SAP Unit-2	72	63	163	138	-14% ↓
SAP Unit-4	18	15	23	16	-24% ↓
SAP Unit-1	16	13	24	17	-25% ↓
Unit-5 SAP	4	3	13	7	-41% ↓
Shopfloor	44	36	106	72	-28% ↓
Idea PLM	8	5	34	20	-40% ↓
GSD	12	5	71	57	-25% ↓
Bank Intergration	26	19	56	34	-35% ↓
Ruber	18	14	35	25	-26% ↓
Non SAP - Production App DBs	6	4	19	13	-32% ↓
Fastreact	40	61	249	223	-2% ↓
Darwin	11	4	62	62	-10% ↓
ECC Cloud connector	5	1	54	26	-54% ↓
KoFax	11	6	128	35	-71% ↓
E Transport	58	2	246	8	-97% ↓
Unit-2 Dye system	2	0	19	15	-29% ↓

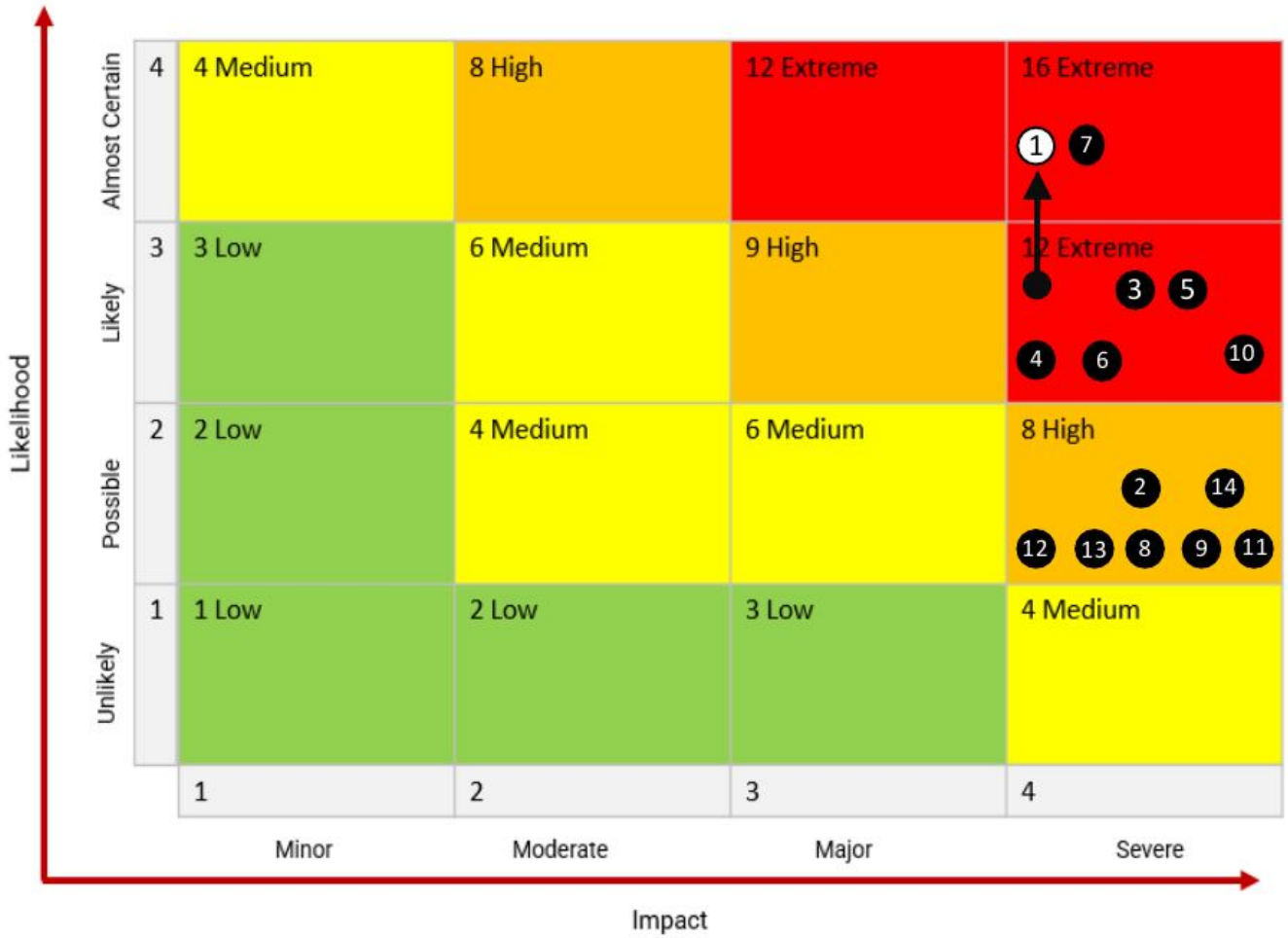
Customer-N

Factory Partner Risk Assessment Findings

Risk Rating	Finding	Suggested Remediation
Minor	Inadequate Password Requirements	• It is advised to implement the following password requirements for XYZ standard and privileged user accounts: • Account lock-out should be set at after 15 mins of inactivity and after 6 unsuccessful log-in attempts • Enable “check for two identical, consecutive characters” as part of password complexity checks.
Informational	Open-Source Software (Snipe-IT) is being used for IT Asset Management	• Upgrade to a commercial solution/enterprise plan • Conduct regular security assessments and audits of OSS tools
Informational	Database is not encrypted	• Configure systems to enable encryption at rest for XYZ DB servers.

Pre-read & Present

Cyber Risk Grid (Q2, 2025)



Up to USD 10,000	USD 10,000 – 500k	USD 500k – 1.5mn	> USD 1.5 Mn

Please refer to the appendix for the KRIs

#	Headline Risk
1	Risk of an attack by a cyber criminal due to lack of employee awareness.
2	Risk of an attack by a cyber criminal as result of using unpatched /vulnerable/End of Life/End of Support software's and/or applications and/or EOL Hardware devices
3	Risk of attack by a cyber-criminal, exploiting vulnerabilities in unsupported systems devices leading to system downtime - Embedded Devices
4	Risk of Cyber Security incident as a result of SBU/JVs not adhering to the XYZ TS standards - XYZ-Sub- / XYZSub-BUSA / Sub-C
5	Risk of a cyber security Incident as a result of a vulnerability/vulnerabilities in the core business system (SAP) - For Unit-1/Matrix /Unit-2
6	Risk of a cyber security Incident as a result of a vulnerability/vulnerabilities in the core business system
7	Risk of a cyber security incident as a result of an attack by a cyber criminal as a result of a supply chain attack
8	Risk of a cyber security Incident as a result of an unmanaged IT Asset within XYZInfrastructure. Unmanaged Server /Laptop /API Connection
9	Risk of a cyber security incident as a result of Shadow IT
10	Risk of a Cyber security incident as a result of a device/system misconfiguration i.e. Misconfiguration in a AD Server or Perimeter firewall and/or System.
11	Risk of a Cyber Security incident as a result of inadequate IT Asset Management Policy
12	Risk of a Cyber Security Incident as a result of a malware infection
13	Risk of Cyber Security Incident as a result of activities of State Sponsored and/or organized crime cyber criminals /cyber terrorists targeting XYZHoldings
14	Risk of a cyber security incident /intrusion as a result of lack of adherence to standard operating procedures within XYZTechnology Services

APPENDIX 1



07.

Open Discussion and Q&A

Pre-read

Cyber Risk Grid – Key Risk Indicators (Q2, 2025)

#	Headline Risk	KRI
1.	Risk of an attack by a cyber criminal due to lack of employee awareness.	Include phishing simulation tracker with victim out of total users Reduction Plan 28% clicks rate - Almost certain <10% click rate - Likely <5% click rate - Possible <3% click rate - Unlikely
2.	Risk of an attack by a cyber criminal as result of using unpatched /vulnerable/End of Life/End of Support software's and/or applications and/or EOL Hardware devices	Reduction Plan - (end devices 88%, servers 75%) - Almost Certain (end devices 86%, servers 82%) - Likely (end devices 95%, servers 90%) - Possible (end devices 100%, servers 100%) - Unlikely
3.	Risk of attack by a cyber-criminal, exploiting vulnerabilities in unsupported systems devices leading to system downtime - Embedded Devices	Develop list of devices other than Workstations and Servers -> list and vendor patch release status
4.	Risk of Cyber Security incident as a result of SBU/JVs not adhering to the XYZ TS standards - XYZ-Sub- / XYZ Sub-B USA / Sub-C	List of non-governed XYZ entities-> compliance level for security (Endpoint security, Email security, Internet security, Application security, Network Security) List of critical vendors->compliance level Self Assessment to be provided Self assessment score average < 50% - Almost certain <75% - Likely <85% - Possible <95% - Unlikely
5.	Risk of a cyber security Incident as a result of a vulnerability/vulnerabilities in the core business system (SAP) - For Unit-1/Matrix /Unit-2	List of Tier 1 applications, VA conducted for Tier 1 application <70% - Almost Certain <80% - Likely <90% - Possible 100% - Unlikely

Cyber Risk Grid – Key Risk Indicators (Q2, 2025)

#	Headline Risk	KRI
6.	Risk of a cyber security Incident as a result of a vulnerability/vulnerabilities in the core business system	List of Tier 1 applications, VA conducted for Tier 1 application <70% - Almost Certain <80% - Likely <90% - Possible 100% - Unlikely
7.	Risk of a cyber security incident as a result of an attack by a cyber criminal as a result of a supply chain attack	List of critical vendors->compliance level Self Assessment to be provided Self assesment score average < 50% - Almost certain <75% - Likely <85% - Possible <95% - Unlikely
8.	Risk of a cyber security Incident as a result of an unmanaged IT Asset within XYZ Infrastructure. Unmanaged Server/Laptop /API Connection	A-% of devices deployed through intune B-% of local admin accounts detected C-% of browserware detected in CS IT hygiene Almost certain (A <80%, B<10%, C>300) Likely (A<90%, B<5%, C<300) Possible (A<95%, B<1%, C<100) Unlikely (A=100%, B=0, C<50)
9.	Risk of a cyber security incident as a result of Shadow IT	
10.	Risk of a Cyber security incident as a result of a device/system misconfiguration i.e. Misconfiguration in a AD Server or Perimeter firewall and/or System.	List of domain servers, firewall baseline configuration < 80% compliance - Almost certain <85% compliance - Likely <95% compliance - Possible 100% compliance - Unlikely
11.	Risk of a Cyber Security incident as a result of inadequate IT Asset Management Policy	A-% of devices enrolled through auto pilot B- % of devices enrolled through Intune C- Device lost case wipe average time Almost certain (A <80%, B<20%, C<5 days) Likely (A<90%, B<5%, C<3 days) Possible (A<95%, B<5%, C<2 days) Unlikely (A=100%, B=0,

Cyber Risk Grid – Key Risk Indicators (Q2, 2025)

#	Headline Risk	KRI
12.	Risk of a Cyber Security Incident as a result of a malware infection	A-Non-Deployment of CrowdStrike for XYZ assets B-Coverage of mailboxes through Mimecast A< 50 endpoints, B<95% - Almost certain A<30 endpoints, B<98% - Likely A<20 endpoints - Possible 100% compliant on CS, B<99.5 - Unlikely
13.	Risk of Cyber Security Incident as a result of activities of State Sponsored and/or nation state cyber criminals /cyber terrorists targeting XYZ Holdings	Number of threat intel incidents detected (numbers to be defined after setting up SOC radar process)
14.	Risk of a cyber security incident /intrusion as a result of lack of adherence to standard operating procedures within XYZ Technology Services.	

End of Pre-read | THANK YOU